

Databehandleravtale

Revidert utkast – til gjennomgang. Markerte avsnitt er foreslåtte justeringer fra Databehandler. Versjon 15.05.2026.

Til oppdragsgiver: Vi stiller oss bak avtalen i hovedsak og er klare for oppstart. Gulmarkerte avsnitt er foreslåtte justeringer, tilpasset at oppdraget er en avgrenset MVP-leveranse utført av et lite spesialistmiljø via Folq. Vi er fleksible på ordlyden så lenge ansvarsbegrensning (pkt. 12) og prinsippet om syntetiske data (Bilag 1) ivaretas.

Denne databehandleravtalen ("Avtalen") er inngått [dato] mellom:

Dr.Dropin BHT AS, organisasjonsnummer 927 103 036	("Behandlingsansvarlig")
Console Holding AS, organisasjonsnummer 936 680 259	("Databehandler")

heretter hver for seg også omtalt som "Part", og samlet som "Partene".

Denne Avtalen består av denne generelle avtaleteksten og følgende Bilag: Bilag 1: Beskrivelse av behandlingen. Bilag 2: Godkjente Under-Databehandlere.

1. Innledning

Denne Avtalen regulerer Partenes rettigheter og forpliktelser i henhold til Forordning (EU) 2016/679 ("GDPR") og gjeldende norsk lov som gjennomfører GDPR (heretter samlet "Personvernlovgivningen"). Begrepene "personopplysning", "behandlingsansvarlig", "databehandler", den "registrerte", "behandling", "brudd på personopplysningssikkerheten", "tilsynsmyndighet" og "tredjestater" forstås på samme måte som etter Personvernlovgivningen.

2. Formål og behandlingsaktiviteter

Partene har inngått en oppdragsavtale om kjøp av utviklingstjenester ("Oppdragsavtalen"), formidlet gjennom Folq. I forbindelse med Databehandlerens gjennomføring av tjenestene vil Databehandleren kunne behandle personopplysninger på vegne av den Behandlingsansvarlige. Ved motstrid mellom Oppdragsavtalen og denne Avtalen, skal Avtalen ha forrang for forhold som angår behandling av personopplysninger. Kategoriene personopplysninger og registrerte, formålet og arten av behandlingen er nærmere beskrevet i Bilag 1.

Databehandleren skal ikke behandle personopplysningene i større omfang, på andre måter eller til andre formål enn det som er nødvendig for å oppfylle forpliktelsene etter Oppdragsavtalen og Personvernlovgivningen, og ikke til andre formål uten den Behandlingsansvarliges skriftlige samtykke.

3. Krav til behandlingen

3.1 Generelle krav

Databehandleren skal kun behandle personopplysningene i samsvar med Avtalen, den Behandlingsansvarliges dokumenterte instruksjer og Personvernlovgivningen. Begrensningen gjelder ikke der Databehandleren etter EU-/EØS-lovgivning er forpliktet til annet; ved slik forpliktelse varsles den Behandlingsansvarlige umiddelbart med mindre varsel er i strid med rettsgrunnlaget. Mener

Databehandleren at en instruks er i strid med Personvernlovgivningen, skal den Behandlingsansvarlige umiddelbart informeres. Databehandleren skal sikre konfidensialitet, integritet og tilgjengelighet, og alle personopplysninger behandles konfidensielt, også etter Avtalens opphør.

3.2 Overføring til tredjestater

Databehandleren skal ikke overføre eller gi tilgang til personopplysningene utenfor EØS uten den Behandlingsansvarliges skriftlige forhåndssamtykke, og ikke til land uten tilstrekkelig beskyttelsesnivå anerkjent av EU-kommisjonen. Den Behandlingsansvarlige kan kreve nødvendige beskyttelsestiltak, herunder EU-kommisjonens standardavtaler.

3.3 Krav til personell

Databehandleren skal sørge for at personopplysninger kun behandles av personell som er (a) kjent med Personvernlovgivningens krav, (b) opplært i å beskytte personopplysninger, (c) autorisert og kun i henhold til Avtalens formål, (d) underlagt taushetsplikt, og (e) gitt tilgang basert på tjenstlig behov.

4. Sikkerhet

4.1 Informasjonssikkerhet

Databehandleren skal gjennomføre egnede tekniske og organisatoriske tiltak for et tilstrekkelig sikkerhetsnivå, tilpasset teknisk utvikling, implementeringskostnad, behandlingens art, omfang og risiko, herunder ved behov pseudonymisering/kryptering, robusthet, gjenoppretting og regelmessig testing. Databehandleren skal ha rutiner for tilgangsstyring etter tjenstlig behov, avdekke og dokumentere avvik, og varsle om endringer i risikobildet. Dokumentasjon av tiltak gjøres tilgjengelig på forespørsel.

4.2 Brudd på personopplysningssikkerheten

Ved brudd på personopplysningssikkerheten skal Databehandleren uten ugrunnet opphold, og normalt senest innen 48 timer etter at bruddet er oppdaget, varsle den Behandlingsansvarlige og gi nødvendig informasjon og bistand slik at den Behandlingsansvarlige kan oppfylle sine rapporteringsplikter. Databehandleren skal iverksette nødvendige tiltak for å begrense virkningen av bruddet.

Justert fra 24 til 48 timer for å gi et lite team realistisk handlingsrom; fortsatt godt innenfor Behandlingsansvarliges 72-timersfrist. 24 timer aksepteres dersom dette er et krav.

5. Vurdering av personvernkonsekvenser

Blir Databehandleren oppmerksom på at behandlingen vil medføre høy risiko for de registrertes rettigheter, skal den Behandlingsansvarlige informeres uten unødig opphold. Databehandleren skal bistå med gjennomføring av DPIA og eventuelle forhåndsdrøftelser med tilsynsmyndigheten.

6. Samarbeid med Behandlingsansvarlig og tilsynsmyndigheter

Databehandleren skal bistå den Behandlingsansvarlige med å besvare henvendelser fra registrerte (innsyn, retting, sletting, dataportabilitet mv.) og fra tilsynsmyndigheter, og videreformidle henvendelser som mottas direkte.

Bistand etter dette punkt 6 ytes uten kostnad i rimelig omfang. Bistand utover [4] timer per hendelse faktureres etter Databehandlerens ordinære timesats i henhold til Oppdragsavtalen.

7. Innsyn og revisjon

Databehandleren skal etablere og vedlikeholde tilstrekkelige internkontrollrutiner og en protokoll over behandlingsaktiviteter utført på vegne av den Behandlingsansvarlige, gjøre nødvendig informasjon tilgjengelig for å påvise etterlevelse, og muliggjøre revisjoner/inspeksjoner. Revisjoner varsles med rimelig frist (normalt minst 10 virkedager), gjennomføres i ordinær arbeidstid og slik at de ikke unødigg hindrer Databehandlerens leveranse.

8. Bruk av Under-Databehandlere

Databehandleren skal ikke engasjere Under-Databehandlere uten den Behandlingsansvarliges skriftlige forhåndssamtykke, og skal pålegge disse tilsvarende forpliktelser. Godkjente Under-Databehandlere fremgår av Bilag 2; endring krever skriftlig samtykke. Bruk av Under-Databehandlere reduserer ikke Databehandlerens ansvar etter Avtalen. Under-Databehandlere oppført i Bilag 2 ved Avtalens inngåelse anses som godkjent.

9. Avtalens varighet

Avtalen gjelder så lenge Databehandleren behandler personopplysninger på vegne av den Behandlingsansvarlige for formålene beskrevet i Avtalen og Oppdragsavtalen. Ved Databehandlerens vesentlige brudd kan den Behandlingsansvarlige pålegge stans i behandlingen med øyeblikkelig virkning.

Databehandlerens forpliktelser og ansvar etter denne Avtalen opphører ved levering og den Behandlingsansvarliges aksept av leveransen under Oppdragsavtalen, i den utstrekning Databehandler fra dette tidspunkt ikke lenger behandler personopplysninger eller har tilgang til den Behandlingsansvarliges systemer eller data. Databehandler er ikke ansvarlig for behandling, drift, endringer eller sikkerhet etter dette tidspunktet, da dette i sin helhet overtas av den Behandlingsansvarlige.

10. Lagring og sletting

Databehandleren følger den Behandlingsansvarliges instruksjoner om lagring og sletting. Ved opphør kan den Behandlingsansvarlige instruere om retur og/eller sletting av alle personopplysninger; Databehandleren bekrefter skriftlig innen 14 dager at dette er gjennomført, og stanser behandlingen umiddelbart.

11. Meddelelser

Skriftlige meddelelser sendes per post eller e-post. For Behandlingsansvarlig: Nora Huseby, Chief Strategy Officer, nora.huseby@drdropin.no. For Databehandler: Asbjørn Rørvik, [Rolle],

12. Ansvar

Databehandleren er ansvarlig for direkte tap som Behandlingsansvarlig lider som følge av Databehandlerens behandling i strid med denne Avtalen, og for indirekte tap ved forsettlig eller grovt uaktsomt brudd.

Databehandlerens samlede ansvar etter denne Avtalen er begrenset til NOK 3 000 000 per hendelse og samlet per år, med mindre tapet skyldes Databehandlerens forsett eller grove uaktsomhet. Databehandlerens plikt til å holde Behandlingsansvarlig skadesløs for krav fra registrerte og for overtredelsesgebyr/bøter gjelder kun i den utstrekning kravet eller gebyret skyldes Databehandlerens forsettlige eller grovt uaktsomme brudd, og er omfattet av ansvarsbegrensningen ovenfor.

Taket er satt likt Databehandlerens profesjonsansvarsforsikring (formueansvar) via Folq/Storebrand. Et ubegrenset, uforsikret ansvar – særlig for GDPR-gebyrer – står ikke i forhold til oppdragets størrelse. Ansvarstak og skyldkrav er markedsstandard for databehandleravtaler med mindre leverandører.

13. Lovvalg og verneting

Avtalen er underlagt norsk rett. Tvister søkes løst ved forhandlinger, og avgjøres ellers ved norske domstoler med Oslo tingrett som verneting i første instans. Bestemmelsen gjelder etter Avtalens opphør.

Dr.Dropin BHT AS – Nora Huseby, Chief Strategy Officer

Console Holding AS – Asbjørn Rørvik, [Rolle]

Bilag 1 – Beskrivelse av behandlingen

Formål: Forsvarlig utvikling og leveranse av en plattform for innsending og oppfølging av egenmeldinger med integrasjon mot NAV, herunder administrasjon og oppfølging knyttet til ansattes sykefravær.

Behandlingens art: Utvikling, test og feilretting av programvare. Behandlingen kan innebære innsamling, registrering, lagring, organisering, bruk, overføring og sletting.

Tilgang til data: Databehandler skal som hovedregel ikke ha tilgang til reelle person- eller helseopplysninger. Utvikling, test og feilsøking skal skje mot anonymiserte eller syntetiske data, herunder mot NAVs test-/sandbox-miljø. Dersom tilgang til produksjonsdata unntaksvis er nødvendig for feilsøking, skal dette skje etter forhåndsavtale, være tidsbegrenset, logget, og begrenset til det minimum som er nødvendig.

Dette er den enkeltjusteringen som reduserer reell risiko mest – for begge parter – og er fullt forenlig med en MVP-leveranse.

Registrerte: Ansatte hos den Behandlingsansvarliges kunder som sender inn egenmeldinger, samt eventuelle pårørende.

Kategorier av personopplysninger: Kontaktopplysninger (navn, fødselsnummer, e-post, adresse, telefon), pårørendeopplysninger, samt opplysninger i dokumenter/korrespondanse.

Særlige kategorier: Helseopplysninger knyttet til sykefravær/egenmelding. Øvrige særlige kategorier behandles ikke med mindre det er strengt nødvendig og avtalt skriftlig.

Bilag 2 – Godkjente Under-Databehandlere

Følgende Under-Databehandlere er godkjent ved Avtalens inngåelse (alle innen EØS; ingen eksponeres for reelle personopplysninger gitt Bilag 1):

Skyhosting / drift	[f.eks. Vercel / AWS – EØS-region]
Kildekode / CI	[f.eks. GitHub]
Feilovervåking / logging	[f.eks. Sentry – EU-region]
[Annet]	[fylles ut]